

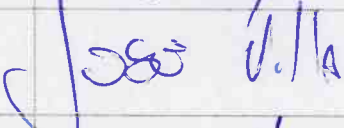
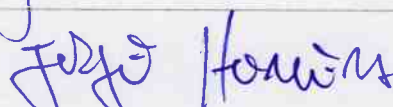


PS-NC-011

POLÍTICA PROTECCIÓN DE DATOS Y PRIVACIDAD DE LA INFORMACIÓN PERSONAL

Sistema de Gestión de Seguridad de la Información – Nivel Central

Versión Oficial Actual v04 – Noviembre 2024

	Responsable	Fecha	Firma
Elaborado		20.11.2024	
Revisado		20.11.2024	
Aprobado		21.11.2024	



Contenido

1	PROPOSITO.	3
2	ALCANCE O AMBITO DE APLICACIÓN.....	3
3	DEFINICIONES.....	3
4	MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS	4
•	Documentos Relacionados	4
•	Leyes o Decretos.....	4
5	ROLES Y RESPONSABILIDADES.	5
▪	División Administración y Finanzas.....	6
▪	Departamento de Recursos Humanos.	6
▪	Departamento de Tecnologías.	6
▪	División Jurídica.	6
▪	Departamento de Auditoría Interna.....	6
▪	Encargado de Seguridad de la Información y Ciberseguridad (CISO).....	6
6	MATERIAS QUE ABORDA.	7
7	DIRECTRICES DE LA POLÍTICA.	7
7.1	Directrices Generales.....	7
7.2	Políticas de sistemas de tratamiento de datos.	7
7.3	En el ejercicio de sus funciones.....	8
8	MECANISMO DE DIFUSIÓN.....	9
9	PERÍODO DE REVISIÓN.....	9
10	EXCEPCIONES AL CUMPLIMIENTO DE LA POLÍTICA	9
11	HISTORIAL Y CONTROL DE VERSIONES.	9

1 PROPOSITO.

El propósito de esta política es definir las directrices para la protección y privacidad de la información personal que se recoja, almacene, procese y transmita, y en general se haga tratamiento de esta, en el Ministerio de Salud. Se busca asegurar un manejo responsable y seguro de los datos, garantizando la confidencialidad, integridad y disponibilidad de la información personal en todas las actividades relacionadas con su tratamiento.

2 ALCANCE O AMBITO DE APLICACIÓN.

Es aplicable a todos los funcionarios (planta, contrata, reemplazos y suplencia), personal a honorarios y terceros (proveedores, compra de servicios, etc.), que presten servicios para la Subsecretaría de Salud Pública y la Subsecretaría de Redes Asistenciales.

Sin perjuicio de lo anterior las obligaciones legales respecto a la confidencialidad de datos, de las personas que trabajan en su tratamiento o acceden a ellos de cualquier forma, no cesan por haber terminado sus actividades en el respectivo organismo.

En cuanto a las temáticas de protección abordadas, el ámbito de aplicación de esta política corresponde al (a los) Dominio(s) de Seguridad de la Información y Controles de Seguridad respectivos, detallados a continuación:

Alcance de Dominios y Controles de Seguridad de la Información		
Estándar	ID Control	Nombre del Control
ISO 27001:2022	A 05.10	Uso aceptable de la información y otros activos asociados
ISO 27001:2022	A 05.34	Privacidad y protección de la Información sensible

3 DEFINICIONES.

Datos Personales: Información de carácter personal que se refiere a cualquier dato que permita identificar o hacer identificable a una persona natural, independientemente del soporte en que se encuentre. Esto incluye, pero no se limita a, nombres, identificadores, datos de contacto, y cualquier otro dato que, ya sea de manera directa o indirecta, pueda vincularse a una persona.

Datos Sensibles: Subconjunto de datos personales aquellos datos personales que se refieren a las características físicas o morales de las personas o a hechos o circunstancias de su vida privada o intimidad, que revelen el origen étnico o racial, la afiliación política, sindical o gremial, la situación socioeconómica, las convicciones ideológicas o filosóficas, las creencias religiosas, los datos relativos a la salud, al perfil biológico humano, los datos biométricos, y la información relativa a la vida sexual, a la orientación sexual y a la identidad de género de una persona natural. La recopilación y el tratamiento de estos datos están sujetos a requisitos adicionales de protección, dado su potencial para causar daño o discriminación a los individuos.

Tratamiento de datos: Cualquier operación o conjunto de operaciones, ya sea mediante procedimientos automatizados o no, que se realicen sobre datos personales. Esto abarca actividades como la recolección, almacenamiento, grabación, organización, elaboración, selección, extracción, confrontación, interconexión, disociación, comunicación, cesión, transferencia, transmisión, o cancelación de datos personales. El tratamiento de datos debe llevarse a cabo en cumplimiento con la normativa aplicable y los principios de protección de datos, garantizando la seguridad y la privacidad de la información.

4 MARCO NORMATIVO Y DOCUMENTOS RELACIONADOS

• Marco Normativo

- NCh ISO27001:2022: Seguridad de la información, ciberseguridad y protección de la privacidad – Controles de seguridad de la información
- El Marco Jurídico referido a los Sistemas de Seguridad de la Información (SSI), publicado en el portal del CSIRT del Ministerio del Interior.
- Decretos Supremos y Normas Internacionales de Seguridad de la Información y Ciberseguridad:
- Leyes relacionadas

• Documentos Relacionados

- Documento del Sistema de Gestión de Seguridad de la Información, disponibles en isalud.minsal.cl.

• Leyes o Decretos

- Ley 19.650, que perfecciona las normas del área de la salud.
- Ley N° 19.966, que Establece un Régimen de Garantías Explícitas en Salud. Promulgada el 25 de agosto de 2004 y publicada el 03 de septiembre de 2004.
- Ley N° 19.628, de 1999, Ministerio Secretaría General de la Presidencia, sobre protección de la vida privada.
- Ley N° 20.120, de 2006, Ministerio de Salud, Subsecretaría de Salud Pública, sobre la investigación científica en el ser humano, su genoma, y prohíbe la clonación humana.
- Ley N° 20.285, de 2008, Ministerio Secretaría General de la Presidencia, sobre acceso a la información pública.
- Ley N° 20.584, de 2012, Ministerio de Salud, Subsecretaría de Salud Pública, regula derechos y deberes que tienen las personas en relación con acciones vinculadas a su atención en salud.
- Ley N° 20.724, de 2014, Ministerio de Salud, modifica el código sanitario en materia de regulación de farmacias y medicamentos.
- Ley N° 21.459, que establece normas sobre delitos informáticos, deroga la ley N° 19.223 y modifica otros cuerpos legales con el objeto de adecuarlos al Convenio de Budapest.
- Ley N° 21.180 Ley de Transformación Digital del Estado, establece directrices para la modernización de los procesos y servicios digitales en instituciones públicas. Tiene implicaciones en la privacidad y la protección de datos personales, ya que establece estándares para la seguridad de la información en servicios y plataformas digitales, fomentando la eficiencia sin comprometer la confidencialidad y la integridad de los datos de los ciudadanos.
- Ley 21.541, que modifica la normativa que indica para autorizar los prestadores de salud a efectuar atenciones mediante telemedicina.



- Ley N° 21.663 sobre Marco de Ciberseguridad, esta ley proporciona un marco para asegurar la ciberseguridad de infraestructuras críticas, que indirectamente impacta en la protección de datos.
- Ley 21.668 establece la interoperabilidad de las fichas clínicas, sobre protección de datos establece un marco legal para salvaguardar la privacidad y los derechos de los ciudadanos en relación con sus datos personales.
- Decreto 273, de 2022, que establece la obligación de reportar incidentes de ciberseguridad a los organismos del Estado al CSIRT de gobierno.
- Decreto con Fuerza de Ley N°29, de 2005, Ministerio de Hacienda, que fija texto refundido, coordinado y sistematizado de la Ley N° 18.834, sobre estatuto Administrativo.
- Decreto con Fuerza de Ley N° 1/19653, Ministerio Secretaría General de la Presidencia, que fija texto refundido, coordinado y sistematizado de la ley N° 18.575, orgánica constitucional de Bases Generales de la Administración del Estado.
- Decreto con Fuerza de Ley N° 725, de 11 de diciembre de 1967, Código Sanitario.
- Decreto N° 533 establece el marco regulatorio en ciberseguridad para las instituciones públicas en Chile, que incluye normas para la protección de la información, la gestión de incidentes de ciberseguridad y la protección de infraestructuras críticas, en las que se procesan datos personales.
- Decreto Supremo N° 7 establece una Norma Técnica de Seguridad de la Información y Ciberseguridad, en concordancia con la Ley N° 21.180 sobre Transformación Digital del Estado. Que tiene el objetivo de definir estándares mínimos de seguridad y ciberseguridad para todos los órganos de la administración pública en Chile, contribuyendo a la protección de los datos personales y a la seguridad de la información en los sistemas digitales gubernamentales.
- Circular N° 711 establece lineamientos sobre el uso de herramientas de inteligencia artificial (IA) en el sector público de Chile, proporcionando directrices para una implementación ética, segura y transparente de estas tecnologías en servicios gubernamentales. Con el objetivo de asegurar que las aplicaciones de IA en el sector público se alineen con los valores de protección de derechos, transparencia y seguridad de la información, además de fomentar la eficiencia y mejorar la calidad de los servicios público.

5 ROLES Y RESPONSABILIDADES.

▪ Funcionarios, personal a honorarios y terceros.

- Utilizar la información únicamente dentro del ámbito de sus competencias y para la finalidad específica para la cual fue recolectada. Está prohibido comunicar, diseminar o ceder de cualquier forma la información a terceros no autorizados, salvo que cuenten con la autorización previa y por escrito del responsable del activo correspondiente o del titular de los datos, cuando aplique.
- Las personas involucradas en el tratamiento de datos personales están obligadas a guardar secreto sobre dichos datos, así como sobre cualquier información y antecedentes relacionados con el banco de datos. Esta obligación se mantiene incluso después de que hayan finalizado sus actividades en este ámbito o su vínculo con el Ministerio de Salud que les habilitó para acceder a esos datos.
- Los datos deberán ser tratados con debida diligencia, sujetándose a las instrucciones



que le imparta el respectivo Subsecretario, en su calidad de responsable del registro o banco de datos.

- Los datos personales deberán ser eliminados o cancelados cuando su almacenamiento carezca de fundamento legal o cuando hayan caducado.
- Los datos personales deberán ser modificados cuando sean erróneos, inexactos, equívocos o incompletos. Se bloquearán los datos personales cuya exactitud no pueda ser establecida o cuya vigencia sea dudosa y respecto de los cuales no corresponda la cancelación.

▪ **División Administración y Finanzas.**

- Incluir cláusulas de confidencialidad y resguardo de la información en los contratos con terceros, conforme a lo establecido en el procedimiento de acuerdos de confidencialidad en contratos con terceros.

▪ **Departamento de Recursos Humanos.**

- Incluir cláusulas de confidencialidad y resguardo de la información en los contratos de honorarios.

▪ **Departamento de Tecnologías.**

- Implementar las medidas técnicas necesarias para la protección de datos personales, garantizando que la infraestructura y los sistemas. También debe colaborar en la gestión de incidentes y en la actualización continua de los sistemas para mitigar riesgos de privacidad y asegurar el cumplimiento normativo.

▪ **División Jurídica.**

- Identificar y difundir las normativas que obligan a la protección de datos y a la privacidad de la información personal, asegurando su estricto cumplimiento. Esto incluye la evaluación continua de las políticas y procedimientos para garantizar que estén alineados con la legislación vigente y las mejores prácticas en materia de protección de datos.

▪ **Departamento de Auditoría Interna.**

- Evaluar el cumplimiento de la Política de Protección de Datos y Privacidad de la Información Personal, proponiendo mejoras para asegurar la conformidad con normativas legales y estándares internos.

▪ **Encargado de Seguridad de la Información y Ciberseguridad (CISO).**

- Establecer, implementar y supervisar las estrategias de protección de datos personales, garantizando el cumplimiento de esta política y de las normativas aplicables.
- Coordinar medidas de seguridad, gestionar y dar respuesta a incidentes relacionados con la privacidad y la seguridad de la información.
- Difundir la política a nivel institucional.
- Fomentar la realización de capacitaciones, charlas y la difusión de contenidos claves para garantizar una adecuada implementación y cumplimiento de la política.



6 MATERIAS QUE ABORDA.

- Uso aceptable de los activos de información.
- Privacidad y protección de la información de identificación personal.

7 DIRECTRICES DE LA POLÍTICA.

7.1 Directrices Generales.

La adopción de las siguientes directrices generales fortalecerá la protección de datos en el Ministerio de Salud, promoviendo así un entorno seguro y confiable para el manejo de información sensible:

- Todos los funcionarios, el personal a honorarios y los terceros deben estar plenamente informados sobre las restricciones relacionadas con el tratamiento de datos e información que puedan conocer en el ejercicio de sus funciones.
- Se requiere que los funcionarios, el personal a honorarios y los terceros que participen en el tratamiento de datos personales o sensibles mantengan la confidencialidad de dicha información, especialmente cuando provenga de fuentes no accesibles al público.
- Todos los datos personales o sensibles, independientemente del medio en que se encuentren, deben ser protegidos y resguardados adecuadamente por quienes tienen la responsabilidad de gestionarlos.
- Los datos personales sólo pueden ser tratados dentro del ámbito de las competencias del órgano en general y en particular dentro de las funciones encargadas a cada colaborador.
- La implementación de tecnologías como la inteligencia artificial en el sector público debe seguir las directrices establecidas en la Circular N° 711, asegurando que su uso sea ético, seguro y transparente, alineándose con los valores de protección de derechos, transparencia y seguridad de la información, además de fomentar la eficiencia y mejorar la calidad de los servicios públicos.
- En el marco de la Ley N° 21.180 sobre Transformación Digital del Estado, se fomentará la gestión documental electrónica y la interoperabilidad entre organismos, garantizando que estos procesos se realicen con los máximos estándares de privacidad y protección de datos personales.

7.2 Políticas de sistemas de tratamiento de datos.

Todos los sistemas o aplicaciones que manejen datos personales en el Ministerio de Salud deben ser diseñados y desarrollados para garantizar el cumplimiento de las obligaciones de reserva y secreto, de acuerdo con la naturaleza de la información. En este contexto, los sistemas que procesen datos sensibles deberán adherirse a las siguientes reglas:

- **Privacidad por defecto:** Los sistemas y aplicaciones serán configurados de manera que el acceso a los datos sea restringido a las personas y usos previamente definidos, debiendo ejecutarse una acción consciente y trazable para cambiar el modelo de acceso a los datos. Adicionalmente, la gestión de datos incluirá técnicas de anonimización, seudonimización o encriptación de datos, de acuerdo con los requerimientos



funcionales que se definan previamente.

- **Seguridad en el diseño:** Los sistemas y aplicaciones deberán ser desarrollados de forma tal que incluyan sistemas de verificación permanente de brechas de seguridad. Asimismo, los sistemas deberán estar diseñados para adoptar las medidas urgentes y necesarias para el resguardo de los datos personales en caso de un incidente de seguridad que pudiere afectarlos.
- **Responsabilidad demostrable:** Los sistemas y aplicaciones deben permitir la trazabilidad de todas las operaciones de tratamiento de datos personales, facilitando la verificación y demostración de dichas operaciones en cualquier momento. Esto incluye el registro de auditorías y el mantenimiento de logs de acceso.
- **Segregación datos y de funciones:** El diseño de los sistemas deberá considerar perfiles diferenciados por competencias, de forma tal que sólo puedan acceder a los datos personales los profesionales que se encuentren legalmente facultados para acceder a ellos. Asimismo, el procesamiento y almacenamiento de los datos debe ser segmentado en función de su clasificación de sensibilidad, minimizando el riesgo de acceso no autorizado.

7.3 En el ejercicio de sus funciones.

- La toma de conocimiento se realizará según el tipo de contrato, conforme a lo indicado a continuación:
 - Funcionarios (Planta, contrata, reemplazos y suplencias): Se regirán por lo establecido en el D.F.L. N° 29, de 2005, del Ministerio de Hacienda, que fija el texto refundido, coordinado y sistematizado de la Ley N° 18.834 sobre Estatuto Administrativo, prestando especial atención a lo señalado en los artículos 61, 84 y 85.
 - Honorarios: Se formalizará mediante una cláusula de confidencialidad en el contrato de honorarios.
 - Terceros: Se incluirán cláusulas de seguridad y confidencialidad en los contratos y se regirán por el "Procedimiento de Acuerdos de Confidencialidad en Contratos con Terceros" y las respectivas bases de adquisiciones.
- A través de estos instrumentos, los funcionarios, el personal a honorarios y los terceros se comprometen a utilizar la información exclusivamente para la finalidad legítima específica que justifique su acceso a la misma. Asimismo, se obligan a no comunicar, diseminar ni de ninguna otra forma hacer pública la información a ninguna persona, natural o jurídica, salvo que cuenten con la autorización previa y por escrito del responsable del activo correspondiente, de acuerdo con las normas referidas en la presente política.
- Todos los funcionarios y el personal involucrado en el tratamiento de datos personales deberán participar, al menos, en capacitaciones, talleres, charlas y actividades de difusión sobre las políticas de seguridad de la información, que incluyan aspectos de



privacidad y protección de datos que sean impartidos por la Institución.

8 MECANISMO DE DIFUSIÓN.

La comunicación de la presente política se efectuará de manera que el contenido de la documentación sea accesible y comprensible para todos los usuarios, a lo menos se deberá hacer difusión mediante los siguientes canales:

- Publicación en la intranet de Minsal <http://isalud.minsal.cl/>
- Correo informativo.
- Publicación en el sitio web Minsal http://www.minsal.cl/seguridad_de_la_informacion/

9 PERÍODO DE REVISIÓN.

El presente procedimiento deberá ser revisado cada dos años o cuando ocurran cambios significativos para garantizar que:

- Sigue siendo adecuado para su propósito y preciso.
- Refleja los cambios en las tecnologías.
- Está alineado con la legislación vigente, los estándares internacionales y las mejores prácticas.

10 EXCEPCIONES AL CUMPLIMIENTO DE LA POLÍTICA

En situaciones excepcionales, el Jefe de Departamento TIC, el CISO o el Comité de Seguridad de la Información tendrán la facultad de evaluar y establecer condiciones específicas para la excepción al cumplimiento de las directrices establecidas en esta política, siempre que tales excepciones no infrinjan la legislación vigente ni comprometan la seguridad de la información.

Cada excepción deberá ser debidamente documentada, y se deberá iniciar un proceso de revisión de la política en el que se determinará si es necesario incorporar directrices adicionales o realizar modificaciones específicas.

11 HISTORIAL Y CONTROL DE VERSIONES.

Versión	Fecha	Pág. o Sección modificada	Motivo del cambio
01	Octubre 2014	Todas	Creación del documento
02	Octubre 2016	Alcance, Difusión Revisión y Medición	Actualización de la referencia normativa de la norma ISO 27001
03	Junio 2020	Alcance, Roles y Responsabilidades. Directrices, normativa, excepciones al cumplimiento de la política	Actualización del documento y normativa 27001:2013



Versión	Fecha	Pág. o Sección modificada	Motivo del cambio
04	Noviembre 2024	Pag 2, 4-5, 6,9 Normativa ISO 27002:2022, Leyes y decretos, Periodo revisión Responsabilidades, Excepciones	Actualización Normativa ISO 27002:2022

